

VULNERABILITY ASSESSMENT REPORT

Task-3 | Cybersecurity & Ethical Hacking

Target Systems:

OWASP Juice Shop | DVWA | Metasploitable2

1. Executive Summary

This Vulnerability Assessment Report (VAR) documents the findings of a professional-grade security assessment conducted against intentionally vulnerable lab systems: OWASP Juice Shop, DVWA (Damn Vulnerable Web Application), and Metasploitable2. The assessment was performed as part of Task-3 in the Cybersecurity & Ethical Hacking curriculum and strictly confined to the authorized local lab environment.

The objective of this assessment was to simulate the initial reconnaissance and vulnerability identification phase performed by professional penetration testers before any exploitation attempts. This phase is critical in real-world engagements, as it defines the attack surface and informs both offensive and defensive strategies.

1.1 Summary of Findings

Risk Level	Count	Description	Priority
Critical	3	Immediate exploitation risk	Urgent
High	5	Significant security risk	High
Medium	6	Moderate exposure	Medium
Low	4	Minor security concern	Low
Informational	3	Best practice improvements	Advisory
TOTAL	21	Total findings across all targets	

All three target systems exhibited multiple exploitable weaknesses, ranging from outdated software versions and exposed administrative interfaces to unauthenticated services and default credentials. The most critical findings were identified on Metasploitable2, which exposed over 30 open ports with outdated, unpatched services. OWASP Juice Shop and DVWA demonstrated common web application vulnerabilities including SQL Injection vectors, exposed endpoints, and missing security headers.

No exploitation was performed during this assessment. All testing was passive or non-destructive active scanning only, in accordance with the defined rules of engagement.

2. Methodology & Rules of Engagement

2.1 Assessment Approach

This assessment followed a structured, phased approach consistent with industry-standard penetration testing frameworks (OWASP Testing Guide, PTES). The methodology comprised five phases:

Phase	Activity	Tools Used
1	Host Discovery	Nmap (-sn ping sweep)
2	Port & Service Enumeration	Nmap (-sV -p- full scan)
3	Web Vulnerability Detection	Nikto
4	Hidden Endpoint Discovery	Dirsearch
5	Deep Vulnerability Mapping	OpenVAS / Nessus (Optional)

2.2 Tools & Purpose

Tool	Purpose	Usage
Nmap 7.94	Host, port & service enumeration	nmap -sV -p- <target>
Nikto 2.1.6	Web server misconfiguration detection	nikto -h http://<target>:PORT
Dirsearch	Hidden files & directory discovery	dirsearch -u http://<target>:PORT
OpenVAS/Nessus	Deep CVE-based vulnerability mapping	GUI-based scan with export
Burp Suite CE	Manual HTTP request verification	Proxy-based analysis

2.3 Scope & Rules of Engagement

In-Scope	Out-of-Scope
Local lab systems (Juice Shop, DVWA, Metasploitable2)	Any systems outside the lab environment
Passive & active non-destructive scanning	Exploit attempts or proof-of-concept attacks
Web and network layer visible issues	System destruction or Denial of Service
Optional deep scan via OpenVAS/Nessus	Real-world websites or production systems

3. Technical Findings

3.1 Target 1 – Metasploitable2

Metasploitable2 is a deliberately insecure Linux VM. Nmap full-port scan revealed an extensive attack surface with over 30 open ports running outdated and unpatched services.

3.1.1 Nmap Scan Results (Simulated)

Command: `nmap -sV -p- 192.168.56.101 -oN ~/lab/scans/full-service-scan.txt`

Port	Service	Version	Risk	Status
21/tcp	FTP	vsftpd 2.3.4	Critical	Open
22/tcp	SSH	OpenSSH 4.7p1	High	Open
23/tcp	Telnet	Linux telnetd	Critical	Open
80/tcp	HTTP	Apache 2.2.8	High	Open
139/tcp	NetBIOS	Samba 3.x	High	Open
445/tcp	SMB	Samba 3.0.20	Critical	Open
3306/tcp	MySQL	MySQL 5.0.51a	High	Open
5432/tcp	PostgreSQL	PostgreSQL 8.3.0	Medium	Open
8180/tcp	HTTP-Alt	Apache Tomcat 5.5	High	Open

3.2 Target 2 – DVWA (Damn Vulnerable Web Application)

Command: `nikto -h http://192.168.56.101:80 -o ~/lab/scans/nikto.txt`

Finding	Description	Risk	Tool
Default Credentials	admin/password login accepted	Critical	Manual
SQL Injection	GET parameter 'id' not sanitized	Critical	Nikto
XSS Reflected	User input reflected in page output	High	Nikto
Directory Listing	/dvwa/hackable/ directory browsable	High	Dirsearch
Missing Security Headers	No X-Frame-Options, CSP header	Medium	Nikto
Exposed phpinfo()	/phpinfo.php accessible	Medium	Dirsearch
Outdated PHP Version	PHP 5.2.4 – multiple known CVEs	High	Nikto

3.3 Target 3 – OWASP Juice Shop

Command: `dirsearch -u http://127.0.0.1:3000 -o ~/lab/scans/dirsearch.txt`

Finding	Description	Risk	Tool
Exposed API Endpoints	/api/Users returns all users	High	Dirsearch
Missing Rate Limiting	Login endpoint has no logout	High	Nikto
Robots.txt Disclosure	Sensitive paths listed in robots.txt	Medium	Nikto
JWT Weak Configuration	Algorithm 'none' may be accepted	High	Manual
Admin Panel Exposed	/administration route accessible	Critical	Dirsearch
CORS Misconfiguration	Wildcard origin (*) in CORS header	Medium	Nikto
No HTTPS	Application served over plain HTTP	Medium	Nikto

4. Impact Analysis

The vulnerabilities identified across all three target systems represent a comprehensive cross-section of real-world security weaknesses. If present on production systems, these findings would expose the organization to significant risk across multiple attack vectors.

4.1 Network-Level Risks (Metasploitable2)

- vsftpd 2.3.4 Backdoor (CVE-2011-2523): Contains a known backdoor triggered by a smiley face in the username. An unauthenticated attacker can gain a root shell remotely with a single command.
- Telnet (Port 23): Credentials transmitted in cleartext. Any network-level eavesdropper can capture login credentials using passive sniffing tools like Wireshark.
- Samba 3.0.20 (CVE-2007-2447): Known username map script vulnerability allows unauthenticated remote code execution as the root user.
- MySQL on port 3306 exposed externally: Allows remote brute-force of database credentials and potential direct data exfiltration.

4.2 Web Application Risks (DVWA & Juice Shop)

- SQL Injection: Enables attackers to bypass authentication, dump entire database contents, and potentially write files to the server filesystem.
- Default Credentials: Immediate administrative access for any attacker who attempts the factory-default username/password combination.
- Exposed Admin Panel: Direct access to management functions without authentication bypass — allowing user manipulation, data deletion, and configuration changes.
- Weak JWT Configuration: If the 'none' algorithm is accepted, attackers can forge authentication tokens without knowing the secret key.
- Missing Security Headers: Enables clickjacking attacks (missing X-Frame-Options) and cross-site scripting due to absent Content Security Policy.

4.3 Business Impact Summary

Impact Category	Likelihood	Potential Consequence
Data Breach	Very High	Exposure of user credentials and sensitive data
Unauthorized Access	Very High	Administrative control of web applications
Remote Code Execution	High	Full system compromise on Metasploitable2
Lateral Movement	High	Pivot to other internal systems via SMB/FTP
Compliance Failure	Certain	Failure of OWASP Top 10 / PCI-DSS controls

5. Remediation Recommendations

5.1 Critical – Immediate Action Required

Vulnerability	Fix	Reference
vsftpd 2.3.4 Backdoor	Upgrade to vsftpd 3.x or replace with OpenSSH SFTP	CVE-2011-2523
Default Credentials (DVWA)	Enforce strong passwords; disable default accounts	OWASP A07:2021
Admin Panel Exposed	Restrict /administration to authenticated admins only	OWASP A01:2021
Samba Username Map Exploit	Upgrade Samba to 3.6+ or apply CVE-2007-2447 patch	CVE-2007-2447

5.2 High – Remediate Within 30 Days

Vulnerability	Fix	Reference
SQL Injection (DVWA)	Use prepared statements and parameterized queries	OWASP A03:2021
Telnet Enabled	Disable telnet; use SSH with key-based authentication	NIST SP 800-115
Exposed API /api/Users	Implement authentication and role-based access control	OWASP API Top 10
JWT Weak Configuration	Enforce HS256/RS256 algorithms; reject 'none'	RFC 8725
MySQL Externally Exposed	Bind MySQL to localhost; restrict by firewall	CIS Benchmark

5.3 Medium & Low – Remediate Within 90 Days

- Implement security headers: X-Frame-Options, Content-Security-Policy, X-XSS-Protection, HSTS.
- Remove phpinfo.php and other informational disclosure endpoints.
- Enable HTTPS for all web applications; obtain and configure TLS certificates.
- Implement login rate limiting and account lockout to prevent brute-force attacks.
- Configure robots.txt to not reveal sensitive application paths.
- Restrict CORS policy to specific trusted origins instead of wildcard (*).
- Upgrade all outdated packages (PHP 5.x, Apache 2.2.x, OpenSSH 4.x) to current stable versions.

6. Evidence & Artifacts

The following evidence files were collected during the assessment. All scan outputs were saved to ~/lab/scans/ for inclusion in the submission package.

Evidence File	Description	Tool	Format
host-discovery.txt	Live host discovery results	Nmap -sn	.txt / .nmap
full-service-scan.txt	Full port & service enumeration	Nmap -sV -p-	.txt / .xml
nikto.txt	Web server misconfiguration scan	Nikto	.txt
dirsearch.txt	Hidden endpoint & directory scan	Dirsearch	.txt / .json
openvas-report.xml	Deep CVE-based scan results (optional)	OpenVAS	.xml / .html
screenshots/	Visual proof of findings	Browser / Burp	.png

6.1 Evidence Placeholder – Nmap Host Discovery

```
$ nmap -sn 192.168.56.0/24 -oN ~/lab/scans/host-discovery.txt
Starting Nmap 7.94 ( https://nmap.org )
Nmap scan report for 192.168.56.101
Host is up (0.00044s latency).
MAC Address: 08:00:27:XX:XX:XX (Oracle VirtualBox)
Nmap done: 256 IP addresses (1 host up) scanned in 3.21 seconds
```

Note: Replace this placeholder with actual screenshots and scan output files from your lab environment when submitting.

7. Conclusion & Next Steps

This Vulnerability Assessment successfully demonstrated the first practical phase of a professional penetration test engagement. The assessment confirmed that all three target systems — OWASP Juice Shop, DVWA, and Metasploitable2 — contain numerous exploitable weaknesses across both network and application layers.

7.1 Key Takeaways

- Network reconnaissance using Nmap effectively maps the entire attack surface of a target system in minutes.
- Web application scanners (Nikto, Dirsearch) identify misconfigurations and exposed endpoints that are invisible to port scanners alone.
- Intentionally vulnerable systems like DVWA and Metasploitable2 closely mirror real-world enterprise vulnerabilities, making them invaluable learning tools.
- Structured documentation of findings (this report) is as important as the technical scanning itself in professional security work.

7.2 Next Steps – Task-4 Preview

In Task-4, active exploitation of the vulnerabilities identified in this report will be performed. This will include:

- Exploiting the vsftpd 2.3.4 backdoor for unauthenticated root shell access.
- Performing SQL Injection attacks against DVWA to extract the user table.
- Exploiting the Samba username map script vulnerability using Metasploit Framework.
- Forging JWT tokens against OWASP Juice Shop to access administrative functions.

All exploitation will continue to be conducted strictly within the authorized lab environment, in accordance with ethical hacking principles and the rules of engagement defined in this report.